אבטחת המרחב המקוון, 2023א'

המבחן עם חומר סגור.

החומר הקובע הוא המדריך עבור פרקים 1-4 (כולל ההפניות המתאימות לספר כמובן), והמצגות עבור שאר החומר.

במבחן יהיו חמש שאלות. יש לענות על ארבע מתוכן.

ייתכנו שאלות מסוגים שונים: נכון/לא נכון, הסבר מושגים, אמריקאיות, ושאלות דומות לאלה שהיו בתרגילים. להלן דוגמאות.

דוגמה לנכון/לא נכון – יש לענות נכון/לא נכון <u>ולהסביר בקצרה</u> (משפט עד שניים):

- פישינג אפשרי רק אם הקורבן לוחץ על קישור זדוני שנשלח לו ע"י התוקף
- פיירוול יכול למנוע התקפת DDOS
- פונקצית HASH קריפטוגרפית לא מייצרת התנגשויות
- בהצפנת AES במוד CBC ה-IV לא צריך להיות סודי
- ה-CA שהנפיק תעודה עבור אתר מסוים יכול לפענח את כל התעבורה של אתר זה
- שימוש בקנרית למניעת BO דורש קימפול של הקוד בקומפיילר התומך באופציה זו
- SALT יכול להגן רק מפני התקפות אופליין
- ...

שאלת הסבר מושגים – יש להסביר בקצרה כל מושג (עד חצי עמוד; יש לכלול את כל הפרטים העיקריים בקצרה):

- IDS
- CFB mode
- חתימה אלקטרונית
- הצפנה ציבורית
- פישינג
- וירוס
- תולעת
- SQL Injection
- ...

הסבר אפשרי (למשל) עבור המושג "הצפנת בלוקים":

הצפנת בלוקים היא סכמה סימטרית של הצפנה ופענוח (כגון DES/AES) הפועלת על בלוקים באורך קבוע (כגון 64/128/256). בסכמה זו ההודעה מחולקת לבלוקים וכל בלוק מוצפן כיחידה עצמאית. תוצאת ההצפנה היא בלוק מוצפן באותו האורך. בצד השני הבלוק מפוענח ומתקבל הבלוק המקורי.

הצפנה זו שונה מהצפנת זרם בה ניתן לשלוח יחידות מידע באורך התלוי ברצון ובצרכי המשתמשים.

כאשר משתמשים בהצפנת בלוקים ניתן (וצריך) להשתמש באופני תפעול מתאימים (כגון CBC) כדי לוודא שבלוקים זהים באותה ההודעה יוצפנו באופן שונה (כמובן ל- CBC יש יתרונות נוספים).

שאלות אמריקאיות (יש להסביר במשפט את הבחירה):

1. קיומו בתוכנה, חומרה או תהליך יכול לאפשר לתוקף להשיג הרשאות / גישה למערכת
   א. Vulnerability
   ב. Capability
   ג. Asset
   ד. Countermeasure
   ה. Exploit

2. איזה סוג של קוד עוין מייצג הקוד הבא?

```
usename = read_username();
password = read_password();
if username is "a1b2c3d4e5f6"
    return ALLOW_LOGIN;
if Valid(username, password) // check if username and password are valid
    return ALLOW_LOGIN
return DENY_LOGIN
```

   א. Virus.
   ב. Trojan.
   ג. Worm.
   ד. Backdoor.
   ה. אף אחד

3. אילו מהמשפטים הבאים נכונים בנוגע לאלגוריתם Diffie-Hellman
   א. מסוגל להתמודד מול התקפות אקטיביות בלבד
   ב. מסוגל להתמודד מול התקפות פאסיביות בלבד
   ג. מסוגל להתמודד מול התקפות אקטיביות ופאסיביות
   ד. מאפשר הצפנה סימטרית
   ה. מאפשר הצפנה א-סימטרית

4. איזה משיטות בקרת הגישה הבאות מבוססת על Security labels
   א. Discretionary access control
   ב. Mandatory access control
   ג. Role-based access control
   ד. אף אחת מהשיטות שלעיל
   ה. כל השיטות שלעיל

שאלות דומות לאלו שהיו במטלות, לדוגמה:

- שאלה על קרברוס, למשל:
  - מה מטרת הפרוטוקול?
  - האם הוא חשוף להתקפת מילון אופליין?
  - הסבירו הודעה מסוימת באופן ספציפי (כמובן שההודעה תופיע בבחינה)
  - מה תפקידו של ה-AS
  - ...
- שאלה חישובית על RSA, DHE, וכדומה, למשל:
  - בפרוטוקול דיפי הלמן נבחן הראשוני 11, והיוצר (שורש פרימיטיבי) 2.
    - הראו ש-2 הוא אכן יוצר.
    - תוקף הצליח לקבל לידיו את $Y_A=9$ ו-$Y_B=3$. מהו המפתח המשותף K?
- שאלה על ניתוח פרוטוקול כלשהו
- שאלה על מודלים, ACL, C-Lists...
- חוקים לפיירוול
- ניצול פגיעויות (BO, SQL Injection, XSS)

להלן דוגמה לשאלה על ניתוח פרוטוקול. ראו בממ"נים דוגמאות לשאלות נוספות.

נדון בפרוטוקול הבא המערב הצפנה סימטרית ואסימטרית. נאמר ומשתמש X מעוניין לשלוח הודעה M ל-Y באופן מוצפן. נניח כי לשני המשתמשים יש מפתח RSA (פרטי,ציבורי) , ונניח כי כל אחד מכיר את המפתח הציבורי של השני (הפרטיים כמובן ידועים רק לעצמם). כעת X בוחר מפתח AES רנדומלי ושולח ל-Y את שתי ההודעות הבאות:

1. $E_{RSA}(Y_{PUBLIC}, S_{RSA}(X_{PRIVATE}, K))$
2. $E_{AES}(K, M)$

כאשר E_{RSA} מסמן הצפנת RSA, Y_{PUBLIC} הוא המפתח הציבורי של Y, S_{RSA} מסמן חתימה דיגיטלית מבוססת RSA, ו- $X_{PRIVATE}$ הוא המפתח הפרטי של X. כמו כן E_{AES} מסמן הצפנת AES.

א. האם Y הוא היחיד שמסוגל לפענח את ההודעות המועברות בפרוטוקול?

ב. האם Y יכול להיות בטוח שההודעה M הגיעה מ-X?

ג. האם Y יכול להוכיח ל-Z כלשהו שההודעה M הגיעה מ-X?

ד. הועלתה הצעה לשפר את הפרוטוקול ע"י שליחת ההודעה:

3. $E_{RSA}(Y_{PUBLIC}, (K,S_{RSA}(X_{PRIVATE}, K)))$

במקום ההודעה הראשונה. האם יש בכך יתרון?

בהצלחה!